

Redes y Seguridad de Redes

Cómo viaja un paquete, dónde se rompe, y los controles que evitan que un atacante use tu red como autopista.

- 17 diapositivas

~25 min

Nivel · Iniciación + Práctica

Qué vamos a ver

/01	Por qué la red importa	contexto
/02	Modelo OSI y TCP/IP	capas
/03	Direcciones, puertos y protocolos	2 slides
/04	DNS, HTTP y TLS	la web
/05	Amenazas a nivel de red	MITM · spoofing
/06	DDoS · la amenaza nº1	cifras ENISA
/07	Firewalls e IDS/IPS	2 slides
/08	VPN · IPsec, OpenVPN, WireGuard	cifrado en tránsito
/09	Segmentación, VLAN y Wi-Fi	arquitectura
/10	Lab · descubrimiento + sniffing	manos a la obra

03 · LA RED ES EL MEDIO

Casi todo ataque tiene un componente de red:
phishing por email, exploits remotos, exfiltración, C2...
Si controlas la red, controlas la mitad de la batalla.

Síntesis a partir de ENISA Threat Landscape 2024 y NIST SP 800-41 [1][2]

DDoS · top amenaza 2024

phishing · llega por SMTP

exfil · data sale por HTTPS / DNS

lateral · un host comprometido busca más

OSI vs TCP/IP

El modelo OSI tiene 7 capas teóricas. TCP/IP, el que de verdad usa Internet, las colapsa en 4.

// MODELO OSI (7 CAPAS)

L7	Aplicación	HTTP · DNS · SMTP
L6	Presentación	TLS · MIME
L5	Sesión	NetBIOS · RPC
L4	Transporte	TCP · UDP
L3	Red	IP · ICMP
L2	Enlace	Ethernet · ARP
L1	Física	cable · radio

// MODELO TCP/IP (4 CAPAS)

4	Aplicación	HTTP, DNS, SSH, TLS
3	Transporte	TCP (fiable) · UDP (rápido)
2	Internet	IP · ICMP · enrutamiento
1	Acceso a red	Ethernet · Wi-Fi · ARP

▲ En seguridad cada capa puede atacarse y defenderse: ARP spoofing (L2), DDoS (L3/L4), TLS (L6/7), phishing (L7).

IP, puerto y socket

Dirección IP

// L3

IPv4	192.168.1.10 · 32 bits · agotada en 2011.
IPv6	2001:db8::1 · 128 bits · sucesor oficial.
privadas	10/8, 172.16/12, 192.168/16 (RFC 1918)
loopback	127.0.0.1 · sólo tu máquina.

Puerto

// L4

rango	0 - 65535 · 16 bits.
well-known	0 - 1023 · root/Admin para escuchar.
registrados	1024 - 49151 · asignados por IANA.
socket	IP : puerto identifica de forma única un extremo.

Protocolos esenciales

TCP

Fiable y orientado a conexión. Garantiza entrega, orden y reintentos. Lo usan HTTP, SSH, SMTP, FTP.

UDP

Rápido y sin garantías. "Disparar y olvidar". DNS, NTP, juegos, streaming, VoIP.

IP

Direccionamiento y enrutado. Decide por qué red sale cada paquete. IPv4 / IPv6.

ICMP

Mensajes de control. Quien hace ping habla ICMP. También traceroute y errores de red.

ARP

IP ↔ MAC. Mapea direcciones IP a MAC en la red local. Foco habitual de ataques (spoofing).

DHCP

Asigna IP, gateway y DNS. Lo que negocia tu portátil al conectarse a Wi-Fi.

DNS, HTTP y TLS

DNS

// RFC 1035

qué hace	Traduce <code>openwebinars.net</code> a una IP enrutable.
puerto	<code>53/udp</code> (queries) · <code>53/tcp</code> (zonas grandes, DNSSEC).
jerarquía	root → TLD (<code>.net</code>) → autoritativo → resolver local.
cifrado	DoT (853/tcp) · DoH (443/tcp) para no exponer consultas.

HTTP + TLS

// RFC 9110 · RFC 8446

HTTP/1.1	Texto plano sobre TCP <code>80</code> . Aún en uso interno.
HTTPS	HTTP sobre TLS 1.3 (RFC 8446) en TCP <code>443</code> .
TLS aporta	Confidencialidad · integridad · autenticidad del servidor (CIA en tránsito).
certificado	Cadena X.509 firmada por una CA de confianza. Verifica fecha y CN.

Las 6 técnicas que verás siempre

Sniffing

Capturar tráfico en una red compartida. Con Wireshark o tcpdump cualquiera puede leer lo que no esté cifrado.

defensa · TLS · VPN · switches con port security

ARP spoofing

El atacante miente sobre su MAC para colocarse en medio (MITM). Clásico de redes locales.

defensa · DAI · Dynamic ARP Inspection · 802.1X

DNS spoofing / cache poison

Inyecta respuestas DNS falsas para redirigir tráfico a un servidor del atacante.

defensa · DNSSEC · DoT · resolvers de confianza

MITM (Man-in-the-Middle)

Atacante intercepta y opcionalmente modifica el tráfico entre dos extremos que se creen seguros.

defensa · cifrado E2E · certificate pinning

Port scanning

Mapeo de qué puertos están abiertos. Suele ser el primer paso antes de un ataque.

defensa · firewall · IDS · honeypots

Lateral movement

Una vez dentro, el atacante pivota por la red interna buscando objetivos de mayor valor.

defensa · segmentación · zero trust · EDR

DDoS · saturar para tirar

#1

Las amenazas contra la disponibilidad (DDoS / DoS) son la categoría más reportada en el ENISA Threat Landscape 2024, por encima del ransomware. [1]

+50%

de los incidentes europeos analizados son DDoS o ransomware [1]

L3 · L4 · L7

capas afectadas · desde volumetría a "slow-loris" en HTTP

RDoS

Ransom DoS · paga o te tiramos. Variante en alza [1]

▲ Defensa típica · scrubbing en proveedor (Cloudflare, AWS Shield) + rate-limiting + filtrado de origen + redundancia geográfica.

Firewalls · qué entra y qué sale

Un firewall aplica reglas a cada paquete. La arquitectura clásica define al menos 3 zonas con políticas distintas.

// INTERNET

Zona no confiable

Política por defecto: denegar todo lo entrante salvo lo explícitamente permitido.

stateless reglas por paquete. Simple, sin memoria.

// DMZ

Zona desmilitarizada

Servicios públicos (web, mail). Aislada de la LAN. Cae primero, no contagia el resto.

stateful sigue conexiones. Bloquea respuestas no solicitadas.

// LAN

Red interna

Confianza alta pero finita. Segmentar por roles, no por geografía.

NGFW inspección a L7 + IDS + filtrado por aplicación.

IDS vs IPS

Donde el firewall decide por reglas, el IDS/IPS analiza patrones de tráfico para detectar comportamientos maliciosos.

IDS // passive		IPS // active	
qué hace	Observa el tráfico y alerta cuando ve patrones sospechosos.	qué hace	Lo mismo + bloquea activamente el tráfico malicioso.
colocación	Modo SPAN/mirror · no está en el camino crítico.	colocación	In-line · todo el tráfico pasa por él. Latencia y falsos positivos = problema.
ejemplos	Snort IDS · Suricata (modo IDS) · Zeek	ejemplos	Snort inline · Suricata IPS · NGFW integrados.
basado en	Firmas (reglas) y/o anomalías (ML).	trade-off	Más seguridad, más riesgo de cortar tráfico legítimo.

VPN · tres tecnologías que verás

Una VPN crea un túnel cifrado que extiende una red privada sobre una red pública. Los tres protocolos más usados hoy:

PROTOCOLO	MODELO	CIFRADO	RENDIMIENTO	COMPLEJIDAD
IPsec	Estándar IETF · site-to-site y road-warrior	AES, ChaCha20, modos AH/ESP	alto	alta · IKEv2, perfiles
OpenVPN	SSL/TLS sobre UDP/TCP · clásico open-source	OpenSSL · AES-GCM	medio	media · ficheros .ovpn
WireGuard	Moderno · in-kernel · diseñado para simplicidad	Curve25519 · ChaCha20-Poly1305	muy alto	baja · ~10 líneas conf

Segmentación, VLAN y Zero Trust

El objetivo: que un host comprometido no contagie a toda la organización. Tres ideas que se complementan.

[01]Segmentación física · separar redes por función: usuarios, servidores, IoT, gestión.	net
[02]VLAN · segmentación lógica sobre el mismo switch. 802.1Q etiqueta cada trama.	L2
[03]NAC · 802.1X · sólo se conecta a la red quien se autentica. RADIUS de fondo.	auth
[04]Microsegmentación · políticas por host/aplicación, no por subred. Habitual en cloud y SDN.	cloud
[05]Zero Trust · "nunca confiar, siempre verificar". Cada acceso se autentica y autoriza explícitamente (NIST SP 800-207).	policy
[06]Bastion hosts · entrada única a una zona protegida. Reduce superficie y centraliza auditoría.	access

Wi-Fi seguro

La radio es un medio compartido por naturaleza. Sin cifrado fuerte, cualquiera dentro del rango puede escuchar.

[01] Usa **WPA3-Personal** (SAE) si tu hardware lo soporta. Mata los ataques offline al PSK. cipher

[02] En su defecto, **WPA2-AES**. Nunca **WEP**, nunca **TKIP**, nunca **WPS**. legacy

[03] Empresarial: **WPA2/3-Enterprise + 802.1X + RADIUS**. Una credencial por usuario. auth

[04] Red de **invitados** en una VLAN aislada con acceso sólo a Internet. net

[05] SSID descriptivo pero **sin revelar la organización** o el modelo del AP. opsec

[06] Firmware del router/AP actualizado. Muchos exploits se quedan vigentes durante años. patch

Captura tráfico contra Metasploitable2

// attacker
Kali Linux
172.18.0.2

docker bridge ·
172.18.0.0/16

// target
Metasploitable2
172.18.0.3

QUÉ VAS A PRACTICAR

- › Mapear servicios con **nmap** a distintos niveles de ruido.
- › Capturar paquetes con **tshark** y leer protocolos sin cifrar.
- › Identificar qué tráfico expone credenciales y qué no.
- › Sólo redes que controlas. Fuera de aquí: **delito**.

```
●●● kali@kali · ~/lab-03 · bash
```

[01] Descubre la red y enumera servicios de la víctima:

```
$ nmap -sn 172.18.0.0/24
```

```
$ nmap -sV -p 21,23,80,445 X.X.X.X
```

[02] Captura tráfico con tshark (CLI) filtrando FTP/Telnet:

```
$ sudo tshark -i eth0 -f "port 21" -w lab03.pcap
```

[03] En otra terminal, conéctate por FTP y simula login:

```
$ ftp 172.18.0.3 · msfadmin / msfadmin
```

[04] Para tshark (Ctrl+C) y lee el pcap en texto plano:

```
$ tshark -r lab03.pcap -Y ftp -T fields -e  
ftp.request.command -e ftp.request.arg
```

6 ideas para llevarte

- /01 La red es **el camino** que usan casi todos los ataques: aprender a defenderla rinde mucho.
- /02 Modelo en capas: cada nivel se ataca y se defiende. **L2 ARP, L3/4 DDoS, L7 phishing.**
- /03 Lo no cifrado se lee. **TLS, VPN y DoT/DoH** son la higiene mínima.
- /04 DDoS es la **amenaza nº1** en Europa según ENISA: necesita scrubbing y arquitectura redundante.
- /05 Firewall + IDS/IPS son **complementarios**: el primero filtra, el segundo detecta.
- /06 El futuro es **Zero Trust**: cada acceso se autentica y autoriza, sin confianza implícita por estar "dentro".

SIGUIENTE · TEMA 04

Ethical Hacking y Pentesting

La perspectiva del atacante. Metodología, fases (reconocimiento, explotación, post-explotación) y marcos como PTES y OWASP.

→ continúa en el siguiente vídeo

Para profundizar

Estándares de IETF, NIST e IEEE más los informes de referencia europeos.

[1]	ENISA	European Union Agency for Cybersecurity · <i>Threat Landscape 2024</i> · enisa.europa.eu
[2]	NIST SP 800-41	Rev. 1 · <i>Guidelines on Firewalls and Firewall Policy</i> · csrc.nist.gov
[3]	NIST SP 800-94	<i>Guide to Intrusion Detection and Prevention Systems</i>
[4]	NIST SP 800-207	<i>Zero Trust Architecture</i> · arquitectura de referencia oficial
[5]	IETF RFCs	791, 793, 768 (IP/TCP/UDP) · 1035 (DNS) · 8446 (TLS 1.3) · 9110 (HTTP) · 4301 (IPsec)
[6]	CCN-CERT & INCIBE	Guías STIC sobre redes inalámbricas y bastionado · ccn-cert.cni.es · incibe.es